BroadcastGuard: A Controlled Study of Low-Exponent RSA Broadcast Recovery and Authenticated Multi-Recipient Sharing

Nguyễn Tiến Dũng (23BA14068)
Vũ Minh Châu (23BA14028)
Nguyễn Minh Hiếu (23BA14105)
Lê Đức Anh (23BA14005)
Hoàng Lê Anh Đức (23BA14057)
Lê Vân (2411065)
Phạm Duy Đức Tâm (23BA14253)

University of Science and Technology of Hanoi (USTH)

Abstract

Textbook RSA with a small public exponent can expose one integer message sent unchanged to several recipients. BroadcastGuard connects the exact CRT recovery condition to controlled experiments and authenticated multi-recipient sharing. Across 20 independent RSA key sets, all 560 subset trials agreed with the integer-recovery prediction. Two 96-byte inputs had different thresholds because their integer values differed; recovering the leading-zero sample's integer does not reveal its original byte length. In 60 same-key comparisons, the tested procedure recovered textbook plaintext 60 times and OAEP plaintext zero times, while legitimate OAEP decryption succeeded throughout. Hybrid experiments separate encryption and key wrapping from JSON/Base64 serialization; the latter dominated measured 1 MiB workflows on one machine. These observations support an educational analysis, not a universal security proof.

1 Introduction and motivation

RSA represents plaintext as an integer and applies public modular exponentiation [1]. Without randomized encoding, repeated use of one integer under different public keys with a small exponent creates a relation visible to anyone holding the ciphertexts. This makes textbook RSA a useful cautionary example, not a description of a properly configured RSA-OAEP deployment. Håstad studied broader low-degree, multi-modulus vulnerabilities [2]; our fixed-message case follows from a shorter CRT argument. We ask when this procedure recovers the original *integer* and what changes in a same-key padding comparison.

BroadcastGuard combines a seven-subset conditions analyzer, a same-key textbook/OAEP comparison, authenticated hybrid file sharing, and reproducible evaluation. RSA, CRT, OAEP and GCM are established. Source and evidence and an interactive demonstration are available; the interface is a teaching aid, not independent security evidence.

2 Background and attack model

Eve observes public pairs (n_i, e) and ciphertexts c_i, but no private keys. In the attack experiment, the same byte string is converted to a nonnegative integer M and encrypted without padding under distinct pairwise-coprime RSA moduli, with $e = 3$ and $M < n_i$. For any nonempty observed subset S,

$$c_i = M^3 \bmod n_i, \qquad N_S = \prod_{i \in S} n_i, \qquad X = \mathrm{CRT}(\{c_i, n_i\}_{i \in S}) = M^3 \bmod N_S. \tag{1}$$

For each $i \in S$, set $N_i = N_S/n_i$ and $u_i = N_i^{-1} \bmod n_i$. Pairwise coprimality makes each inverse exist. The implementation computes

$$X = \left(\sum_{i \in S} c_i N_i u_i \right) \bmod N_S. \tag{2}$$

It then computes $r = \lfloor \sqrt[3]{X} \rfloor$ using integer arithmetic and tests $r^3 = X$; no floating-point approximation is used. Since CRT returns $0 \le X < N_S$, the bound $M^3 < N_S$ yields $X = M^3$ and $r = M$.

Conversely, this procedure can return M only if that bound holds. A perfect cube may instead yield a *different* integer. Eve validates public inputs and computes r without ground truth; only the separate experiment evaluator compares r with M.

The evaluator also retains the supplied byte length when converting a candidate integer back to bytes. This length is *not* learned from the ciphertexts: $\texttt{0x00}^{95}\|\texttt{0x02}$ and $\texttt{0x02}$ both represent $M = 2$. Thus E1's "recovered" metric means evaluator-confirmed *integer* equality, not independent recovery of an arbitrary original byte string.

OAEP applies randomized encoding before RSA exponentiation [3, 4]. Its ciphertexts do not encode a common unpadded M^3 relation across recipients. RFC 8017 specifies RSAES-OAEP and the limit $m_{\text{Len}} \leq k - 2h_{\text{Len}} - 2$; RSA-2048 with SHA-256 therefore accepts at most 190 message bytes [4]. Our comparison applies the *same* CRT-and-root procedure to OAEP ciphertext integers to test its observed outcome, without treating them as textbook ciphertexts.

3 System design and experimental method

The educational attack builder generates three RSA-2048/e=3 keypairs for Alice, Bob and Charlie. The public-only attacker checks a shared exponent and pairwise-coprime moduli, combines selected (n_i, c_i) observations by Eq. (2), and tests an exact integer cube root. A separate evaluator checks the candidate integer and bound in Eq. (1); the analyzer enumerates all seven nonempty subsets. In E1, 20 independently generated key-set blocks each test four messages on the *same* three moduli: `B` repeated 1, 96 or 180 times, and 95 zero bytes followed by `0x02`. E2 uses identical keys and plaintext within each textbook/OAEP pair, so key variation cannot explain a within-pair outcome difference. OAEP uses SHA-256, MGF1(SHA-256) and the empty label. Its three samples give 60 paired observations in 20 key-set blocks, not 60 independent key sets.

Secure Sharing uses a separate RSA-2048/e=65537 configuration. For each file, it generates a fresh 256-bit AES key and 96-bit GCM nonce, encrypts file bytes *once* with AES-GCM, and RSA-OAEP-wraps that key independently for each recipient. A compact, canonical JSON header (filename, size, nonce, algorithm identifiers, recipient IDs, public-key fingerprints and wrapped keys) is GCM associated authenticated data; the ciphertext and 16-byte tag are stored as Base64 in a versioned JSON package. A matching private key unwraps the AES key; authenticated decryption returns bytes only after validation. GCM authenticates ciphertext and AAD under the key, not the sender's identity [5].

E3 times nine combinations of 10 KiB, 100 KiB and 1 MiB files with one, three or five recipients, using 20 measured repetitions and two warmups per configuration. Prepared RSA keys are reused for routine workflow timing; independent key generation is timed separately. `perf_counter_ns` intervals distinguish encrypt+wrap, JSON/Base64 serialization, their sum, and decryption for the first valid recipient. All decrypted files are compared byte-for-byte. E4 checks one valid package and ten selected invalid, mismatched or modified cases. The archived official run records its manifest, source commit, raw CSVs and validation status; no observations were discarded.

4 Results and analysis

4.1 The integer boundary, not byte count

Figure 1 reports all seven subset outcomes. Across $20 \times 4 \times 7 = 560$ trials, the inequality in Eq. (1) matched evaluator-confirmed *integer* recovery in every row. The minimum successful interception count was one, two, three and one for the four declared samples, respectively. Both 96-byte inputs have identical storage length, yet $\texttt{B}^{96}$ is a 767-bit integer while the leading-zero sample represents 2. One ciphertext can therefore reveal that sample's integer; reconstructing precisely 95 leading zero bytes additionally requires its original length or an agreed encoding. Any two ciphertexts reveal the $\texttt{B}^{96}$ integer in these trials. This verifies the numerical bound for controlled inputs, not a universal byte-length threshold.

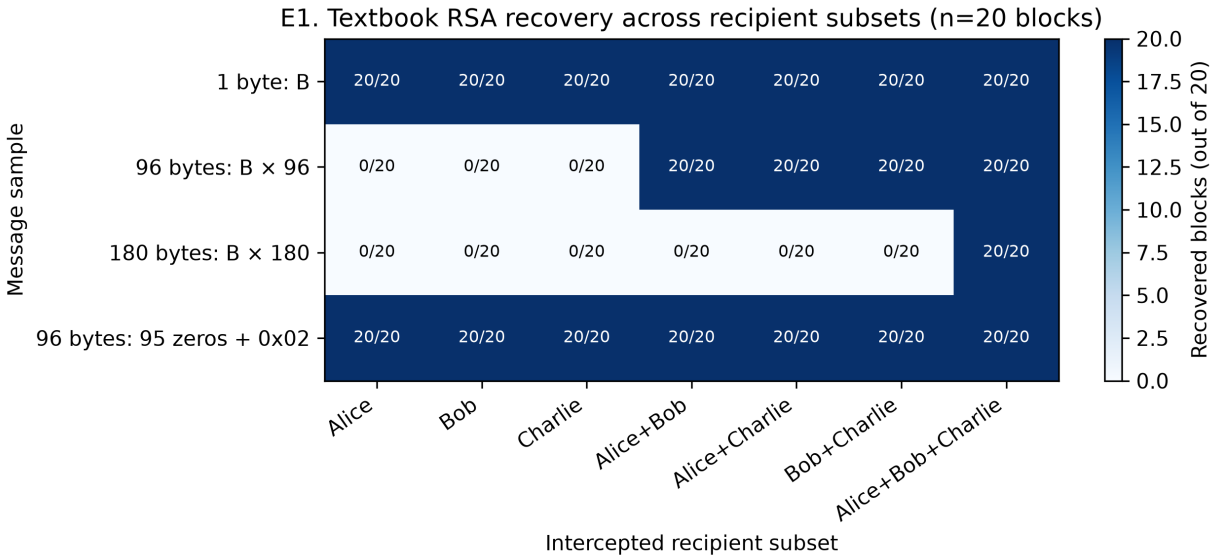


Figure 1: Evaluator-confirmed *integer-representative* recovery for four fixed textbook RSA messages and seven intercepted subsets, across 20 independent RSA-2048/e=3 key-set blocks. Cells show successful blocks out of 20. The leading-zero 96-byte row has $M = 2$; its 96-byte serialization cannot be inferred by Eve without length information.

4.2 Paired padding comparison

Table 1 uses identical plaintext, three recipients, RSA keypairs, exponent and attack procedure within each comparison; only the encryption scheme changes. Textbook encryption repeats the same ciphertext for the same key and message; OAEP's randomized encoding produced distinct repeated ciphertexts in all 60 checks. The tested CRT-and-root computation recovered no original OAEP plaintext, while every legitimate recipient decrypted correctly. These 60 observations are clustered in 20 independent key-set blocks. Their result does not constitute a formal proof of OAEP security or a test of every attack.

Table 1: E2 outcomes across 60 paired comparisons in 20 RSA key-set blocks. Recovery means equality with the original plaintext, checked by the evaluator; decryption is a distinct legitimate-recipient operation.

Scheme	Procedure/outcome	Correct / trials
Textbook RSA	Eve's CRT-and-root recovery	60/60
RSA-OAEP	Eve's same procedure	0/60
RSA-OAEP	Legitimate decryption	60/60

4.3 Hybrid cost and authenticated failure

Figure 2 separates application packaging from cryptographic work. For a 1 MiB file and one recipient, the raw means were 0.479550 ms for encrypt+wrap and 7.232030 ms for serialization; their 7.711580 ms sum excludes RSA key generation. Serialization accounted for 93.78% of that measured mean on this Windows system. This is a cost of the chosen JSON/Base64 workflow, not a weakness of AES-GCM. The three 1 MiB total means were not monotone in recipient count, so small differences should not be interpreted as an algorithmic speed advantage; scheduling and interpreter variability matter. The decryption interval measures only one valid recipient.

The serialized package size is structurally

$$P(L, r) = 4 \left\lceil \frac{L + 16}{3} \right\rceil + H(L, r, f, \mathcal{I}), \tag{3}$$

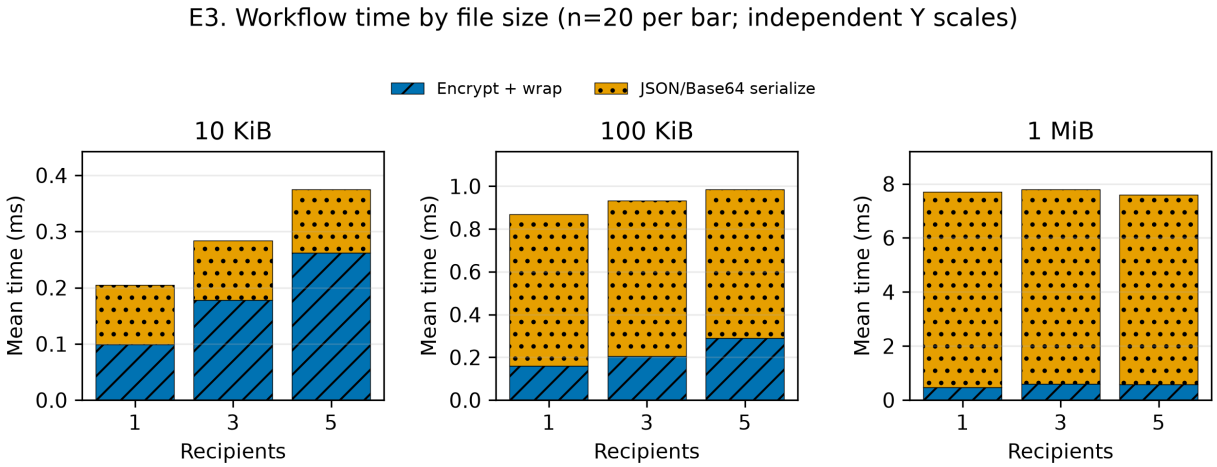


Figure 2: Mean E3 workflow components in milliseconds, 20 timed repetitions per file-size/recipient configuration with prepared keys. Each file-size panel has an independent, zero-based Y-axis scale. Total encryption is encrypt+wrap plus JSON/Base64 serialization; key generation is measured separately.

where L is plaintext bytes, r is recipient count, 16 is the GCM tag length, and H includes JSON structure, filename f, decimal size, nonce, IDs $\mathcal{I}$, fingerprints and one Base64-encoded 256-byte RSA wrapped key per recipient. For the fixed E3 filenames and IDs, this exact accounting matched every observed serialized size; it is not a fitted law for arbitrary metadata. At 1 MiB the observed relative overhead ranged from 33.40% (one recipient) to 33.58% (five), mostly reflecting Base64's approximate one-third expansion rather than the GCM tag alone.

All 11 E4 correctness cases matched expected outcomes: the valid case returned original bytes, and ten malformed, mismatched or modified cases returned no plaintext. Rejection may arise from structure checks, a wrong recipient/key, OAEP failure or GCM authentication; it does not by itself identify malicious tampering.

5 Limitations and discussion

E1 verifies a known elementary condition; Håstad considered broader low-degree modular systems. E2's zero OAEP recoveries concern one procedure and sample, not all attacks. E3's 20 wall-clock timings per configuration come from one Windows computer; scheduling and interpreter effects limit generalization, and decryption covers only the first recipient. E4 is a selected checklist, not an attack population. Sharing assumes authenticated recipient public keys; fingerprints alone do not establish identity. Filename and recipient metadata remain visible. The implementation lacks sender authentication, replay protection, PKI and persistent key management.

6 Conclusion

The bound $M^3 < N_S$ predicted every E1 *integer*-recovery outcome and explains why byte count alone misleads; leading-zero byte strings still require separate length information. In the paired comparison, the tested CRT-and-root method did not recover OAEP plaintext, while intended recipients decrypted. For hybrid files, JSON/Base64 serialization dominated the observed 1 MiB workflow. BroadcastGuard contributes controlled integration, auditable implementation and explicit evidence limits, rather than a new cryptographic algorithm.

References

[1] R. L. Rivest, A. Shamir, and L. Adleman, "A method for obtaining digital signatures and public-key cryptosystems," *Communications of the ACM*, vol. 21, no. 2, pp. 120–126, 1978, doi:10.1145/359340.359342.

[2] J. Hastad, "Solving simultaneous modular equations of low degree," *SIAM Journal on Computing*, vol. 17, no. 2, pp. 336–341, 1988, doi:10.1137/0217019.

[3] M. Bellare and P. Rogaway, "Optimal asymmetric encryption," in *Advances in Cryptology – EUROCRYPT '94*, ser. Lecture Notes in Computer Science, vol. 950. Springer, 1995, pp. 92–111, doi:10.1007/BFb0053428.

[4] K. Moriarty, B. Kaliski, J. Jonsson, and A. Rusch, "PKCS #1: RSA cryptography specifications version 2.2," RFC Editor, RFC 8017, 2016. [Online]. Available: https://www.rfc-editor.org/rfc/rfc8017.html

[5] M. Dworkin, "Recommendation for block cipher modes of operation: Galois/counter mode (GCM) and GMAC," National Institute of Standards and Technology, Special Publication 800-38D, 2007, doi:10.6028/NIST.SP.800-38D.